AI DOC ASSISTANT

ระบบถาม-ตอบเอกสารด้วย RAG ภาษาไทย/อังกฤษ พร้อมอ้างอิงแหล่งที่มา (pilot ภายใน)

NFR และความปลอดภัย

รหัสเอกสาร	ADA-DOC-03
ฉบับ	0.1
วันที่	2026-10-07
สถานะ	ร่างเพื่อพิจารณา

เอกสารภายในฉบับร่าง — ใช้ประกอบการพัฒนาและดูแลระบบ

สารบัญ

1. NFR พร้อมเป้าหมายที่วัดได้

2. Security controls

3. Privacy / PDPA

4. Observability

5. Backup / DR

การอนุมัติ

แหล่งข้อมูล

03 — NFR และความปลอดภัย

1. NFR พร้อมเป้าหมายที่วัดได้

ID	หมวด	เป้าหมาย	วิธีวัด	สถานะ
NFR-01	Availability	health/readiness ทำงานโดยไม่มี key; ยังไม่อ้าง availability ของ staging	probe/smoke ต่อ environment	ผ่าน local + Homelab (2026-08-02: PASS=25, FAIL=0, SKIP=1)
NFR-02	Retrieval quality	≥90% บนชุดไทย/อังกฤษที่อนุมัติ	evaluation ≥20 เคส	ยังไม่รัน
NFR-03	Citation quality	≥95% ของข้อความอ้างถึง source ที่คืน	ตรวจโดยคน/deterministic	ยังไม่รัน
NFR-04	Safety	100% ของเคส no-evidence และ injection fail closed	negative evaluation	KB ว่างผ่าน; ส่วนอื่นยังไม่รัน
NFR-05	Performance	p95 ≤8 วินาที (รวม retrieval + provider)	timed test	ยังไม่รัน
NFR-06	Cost	≤USD 0.05 ต่อคำถามปกติ (เกณฑ์วางแผน)	`cost_usd` ใน response + billing	ยังไม่รัน
NFR-07	Security/privacy	auth, scope, path/type/size, redaction, secret, provider control ผ่านก่อนใช้นอกเดโม	security review + negative test	upload control บางส่วนผ่าน
NFR-08	Durability/recovery	staging RPO ≤15 นาที, RTO ≤2 ชม.; เดโมไม่มีการรับประกัน	restore drill	ยังไม่ทำ
NFR-09	Data deletion	ทุกสำเนาลบตาม policy พร้อม audit	delete test	ยังไม่มี
NFR-10	Rollback	ปิด upload/query กลับสู่ `DEMO_ONLY` ภายในเวลาที่ owner อนุมัติ	rehearsal	ยังไม่ทำ

Scalability: HPA ตั้ง 1–2 replicas บน k3d แต่ Chroma อยู่ใน process ทำให้แต่ละ replica มี knowledge base แยกกัน — การ scale เกิน 1 replica จะให้ผลไม่สม่ำเสมอ **[สมมติฐาน]** จากการอ่านโค้ด

2. Security controls

ควบคุม	สถานะ	อ้างอิง threat
Authentication/authorization	**ไม่มี** — ทุก endpoint เปิด	T-01 (Open)
CORS	allow-list จาก `CORS_ALLOW_ORIGINS` (ค่า default `http://localhost:8000`), `allow_credentials=True`	T-02 — แก้บางส่วนใน `815d8e7`
Upload	ชื่อไฟล์ต้องไม่มี path, นามสกุล allow-list `.pdf/.docx/.txt`, ≤10 MiB (HTTP 413), temp file สุ่มและลบใน `finally`	T-05, T-06
Prompt injection	context ห่อด้วย delimiter + system instruction ห้ามทำตามคำสั่งในเอกสาร; มี `test_prompt_injection_boundary.py`	T-04 (Open จนกว่าจะประเมินกับ provider)
Error handling	ตอบข้อความทั่วไป ไม่ส่ง stack trace	T-11
Secrets	`OPENAI_API_KEY` จาก env/secret store เท่านั้น; Homelab มี secret object แต่เป็นค่า dummy	T-08
Container	non-root UID 65532, HEALTHCHECK `/health`	—
Image	tag immutable `git-<sha>` ห้ามใช้ `:latest`	—

3. Privacy / PDPA

- ข้อมูลที่อนุญาต: เอกสารสังเคราะห์ใน repository เท่านั้น (RULE-001, data classification)
- การส่งเนื้อหาเอกสารไปยัง OpenAI ต้องผ่านการทบทวนเงื่อนไข provider/region ก่อน (T-07) — **[ต้องยืนยัน]**
- โค้ดปัจจุบันไม่เก็บ log คำถาม/คำตอบแบบถาวร; ต้องกำหนด retention ก่อนใช้กับข้อมูลจริง (`data-access-retention.md`)

4. Observability

- ทุกคำถามคืน `latency_ms`, `cost_usd`, `confidence`, `grounded`; `/stats` คืนจำนวนเอกสาร/chunk
- ยังไม่มี structured log, metrics, alert หรือ dashboard ต้นทุน (FR-10)

5. Backup / DR

- ปัจจุบันไม่มี — ข้อมูลอยู่ใน memory (`DEMO_ONLY`)
- แผน: durable vector/object store + backup/restore ตาม `AI-DOC-ASSISTANT-DURABLE-DATA-PLAN.md` และ `operations/runbooks/STAGING-DATA-BACKUP-RESTORE.md`; restore drill ยังไม่รัน

การอนุมัติ

บทบาท	สถานะ	วันที่	ลงนาม
Solution Architect + Security	ร่างเพื่อพิจารณา	2026-10-07	_
Accountable sponsor (risk acceptance)	รอพิจารณา	_	_

แหล่งข้อมูล

- `roles/pilots/ai-doc-assistant/non-functional-requirements.md`, `privacy-impact-assessment.md`, `data-access-retention.md`
- `operations/ai/AI-DOC-ASSISTANT-THREAT-MODEL.md`, `AI-DOC-ASSISTANT-DATA-CLASSIFICATION.md`, `AI-DOC-ASSISTANT-DURABLE-DATA-PLAN.md`, `AI-DOC-ASSISTANT-RECOVERY-DRILL-2026-08-08.md`
- `engagements/internal/solo-empire/ai-doc-assistant/main.py`, `rag_engine.py`, `Dockerfile`
- `clients/solo-empire/ai-doc-assistant/STATUS-2026-08-11.md`, `roles/pilots/ai-doc-assistant/pilot-record.md`